Course: NPTEL Ethical Hacking | Coverage: Lectures 16 to 20 (Lab Setup, Information Gathering & Vulnerability Assessment)

MODULE 1: LECTURE 16 — SETTING UP THE ETHICAL HACKING LAB ENVIRONMENT

1.1 Fundamentals of Virtualization in Ethical Hacking Labs

Simple Explanation: Imagine you want to test driving different cars (sports cars, trucks, vintage sedans) or experiment with dangerous stunt driving without buying multiple physical vehicles or risking a real-world crash. A driving simulator lets you spin up any car inside a safe, isolated digital realm. In cybersecurity, **Virtualization** does exactly that for computers: it lets you build and run multiple completely isolated virtual computers (Virtual Machines or VMs) inside your single physical laptop or desktop.

Why it is Needed: Ethical hacking requires hands-on practice against diverse target operating systems (Windows XP, 7, 10, Server 2016, Metasploitable Linux). Acquiring and maintaining 5 to 10 physical computers is cost-prohibitive, space-consuming, and dangerous if malware escapes onto your home or university network. Virtualization isolates the lab, allows instant snapshotting/restores, and costs zero additional hardware dollars.

Technical Definition: *Virtualization* is the technological process of creating a software-based (virtual) representation of hardware resources—including CPU cores, RAM, storage controllers, network interfaces, and display adapters. The underlying software manager that coordinates these virtual hardware resources is called a **Hypervisor** (or Virtual Machine Monitor).

How it Works Step-by-Step:
1. **Host Operating System:** Your physical machine runs its native OS (e.g., Windows 11, macOS, Ubuntu Linux).
2. **Hypervisor Installation:** A Type-2 Hypervisor (e.g., Oracle VM VirtualBox) is installed on top of the host OS.
3. **Virtual Hardware Abstraction:** VirtualBox intercepts hardware calls from guest systems and maps them to physical host resources.
4. **Guest Operating System Deployment:** You create virtual containers and install guest OSs (like Kali Linux as the attacker, and Windows as the target).
5. **Isolation Boundary:** Memory and CPU execution spaces are strictly compartmentalized so guest attacks cannot crash or infect the host OS.

> **REAL-WORLD ANALOGY: THE APARTMENT BUILDING**
> **Physical Computer (Host):** The entire apartment building frame, electrical main, and water supply.
> **Hypervisor (VirtualBox):** The building manager who allocates rooms, power outlets, and water meters to tenants.
> **Virtual Machines (Guests):** Individual rented apartments. What happens inside Tenant A's room (e.g., painting walls red or breaking a table) stays inside Tenant A's room and does not affect Tenant B across the hall!

1.2 Virtualization Software: Deploying Oracle VirtualBox

What it is: *Oracle VM VirtualBox* is a powerful, free, and open-source cross-platform hypervisor developed by Oracle. While commercial alternatives exist (e.g., VMware Workstation Pro/Player), VirtualBox is preferred in academic and NPTEL environments due to its zero licensing fee, open access, and rich feature set across Windows, macOS, and Linux hosts.

Step-by-Step Installation Procedure:
1. **Download Installer:** Download the official VirtualBox setup package from virtualbox.org.
2. **Execute Setup Wizard:** Run the installer, accept default feature selections (VirtualBox USB Support, Networking, Python Bindings).
3. **Network Interface Warning:** Accept the temporary network interface reset prompt (VirtualBox creates virtual network adapters).
4. **Complete Setup:** Click Finish and launch Oracle VM VirtualBox Manager.

1.3 Installing Kali Linux as the Attacker VM

What Kali Linux Is: Kali Linux is a Debian-derived Linux distribution custom-built for digital forensics, security auditing, and penetration testing. Developed and maintained by Offensive Security, it comes pre-loaded with over 600 specialized security tools (including Nmap, Wireshark, Metasploit, John the Ripper, and The Harvester).

Step-by-Step Creation & Installation Protocol (From Lecture):
1. **Create VM Container:** Click *New* in VirtualBox.
• Name: Kali Linux 2019.2
• Type: Linux | Version: Debian (64-bit)
2. **RAM Allocation:** Allocate **2 GB (2048 MB)** RAM minimum (or 4 GB if host has 16 GB+).
3. **Virtual Hard Disk (VDI):** Choose *Create a virtual hard disk now* using format **VDI (VirtualBox Disk Image)**.
4. **Storage Allocation Type:** Select **Dynamically Allocated** (grows on demand, saving physical host storage) rather than Fixed Size.
5. **Disk Space Size:** Set disk size to at least **20 GB** (lecture recommendation) to allow room for tool suites, wordlists, and updates.
6. **Mount Kali ISO File:** Go to VM Settings → Storage → Controller: IDE → Select 'Empty' Optical Drive → Mount downloaded kali-linux-2019.2-amd64.iso.
7. **Execute OS Installation:**
• Boot VM and select **Graphical Install** or **Install** from boot menu.
• Language & Keyboard: English / American English.
• Hostname & Password: Set hostname (default kali) and create a secure root password.
• Disk Partitioning: Choose **Guided - use entire disk** → *All files in one partition*.
• Write Changes: Confirm 'Yes' to write changes to disk.
• Network Mirror: Select 'No' during install to prevent network delay (updates can be pulled post-install).
• **GRUB Boot Loader:** Select 'Yes' to install GRUB to master boot record, selecting **/dev/hda** (or primary virtual disk).
• Reboot & Login: Login with username root and your set password.

EXAM POINT: KALI LINUX INSTALLATION SPECS TO MEMORIZE

- **Base Distribution:** Debian (64-bit)
- **Recommended RAM:** 2048 MB (2 GB)
- **Disk Format & Sizing:** VDI format, Dynamically Allocated, 20 GB size minimum.
- **Bootloader Target:** GRUB installed to /dev/hda.
- **Default Root Superuser:** Root privilege is required to open raw sockets for Nmap stealth scans!

1.4 Hardware Virtualization in BIOS/UEFI (Intel VT-x / AMD-V)

The Crucial Prerequisite: Before virtual machines can run smoothly or support 64-bit guest operating systems, **Hardware-Assisted Virtualization** must be enabled in the host motherboard's BIOS/UEFI settings.

- **Intel CPUs:** Intel VT-x (Virtualization Technology)
- **AMD CPUs:** AMD-V (AMD Virtualization)

Symptom if Disabled: VirtualBox throws errors like 'VT-x/AMD-V hardware acceleration is not available', restricts guest OS creation to 32-bit only, or causes severe VM performance slowness/freezing.

1.5 VirtualBox Networking Modes & Lab Isolation

Networking Mode	IP Address Assigned	VM to Host Access	Host to VM Access	VM to Internet	Lab Security Isolation
NAT (Default)	Virtual/Private IP (via VirtualBox DHCP)	Yes (routed)	No (hidden behind NAT)	Yes (via Host IP)	High (Hidden from external network)
Bridged Adapter	Same Subnet as Host (from real router)	Yes (LAN peer)	Yes (Direct IP)	Yes (Direct)	Low (Exposed to physical local network)
Host-Only	Private Host-VM Subnet	Yes (Host only)	Yes (Host only)	No	Very High (Isolated from Internet)
Internal Network	Custom Virtual Subnet	No	No	No	Maximum (Isolated completely inside VirtualBox)

NPTEL ASSIGNMENT & EXAM QUESTION HIGHLIGHT: NAT MODE MECHANICS

Question: Which of the following statement(s) is/are true regarding the default networking mode (NAT) in VirtualBox?
Correct Options:
1. It assigns the same virtual/private IP address structure to guest operating systems.
2. Virtual machines using this mode can access the internet.
Why: NAT (Network Address Translation) hides the VM behind the host's physical IP address. The guest gets a virtual IP (e.g., 10.0.2.15), can make outbound requests to the web, but outside devices cannot connect directly into the guest VM!

Module 1 Quick Revision Q&A;:

Q1: What is the primary purpose of a Hypervisor in a penetration testing lab?
Answer: A Hypervisor allows a single physical host machine to create, manage, and run multiple virtual machines concurrently, sharing hardware resources safely.
Q2: What is the difference between Dynamically Allocated and Fixed Size virtual hard disks?
Answer: Dynamically allocated disks grow on the physical drive as space is used inside the VM up to the set limit (saving host disk space upfront), whereas fixed-size disks reserve the entire allocated file size immediately.

MODULE 2: LECTURE 17 — PASSIVE INFORMATION GATHERING & RECONNAISSANCE

2.1 Principles of Reconnaissance: Passive vs. Active Intelligence

Before starting a security audit, an ethical hacker collects intelligence. Reconnaissance (Info Gathering) is the foundational first phase of any security assessment. It is broadly divided into two strategies: *Passive Intelligence* and *Active Reconnaissance*.

Feature / Dimension	Passive Reconnaissance	Active Reconnaissance
Direct Target Touch	NO direct communication with target servers	YES, sends packets directly to target IP
Detection Risk	Zero / Near Zero (Target logs nothing)	High (Firewalls, NIDS, and SIEM log probes)
Information Sources	Public databases, search engines, WHOIS, OSINT	Port scans, banner grabbing, vulnerability scans
Primary Tools	WHOIS, Google Search Operators, Netcraft, Archive.org, TheHarvester	Nmap, Masscan, Nessus, OpenVAS
Legal Boundary	Completely legal (public web data analysis)	Requires explicit Scope of Work (SOW) authorization

2.2 WHOIS Database Lookup & Domain Profiling

What it is: WHOIS is a public query protocol used to query databases that store registered users, assignees, and domain ownership details for Internet resources.

Information Retrieved via WHOIS:
• **Registration Timestamps:** Domain creation, update, and expiration dates.
• **Registrar Details:** Organization holding the domain registration.
• **Authoritative Name Servers:** Core DNS servers handling target traffic.
• **Registrant Contact Info:** Name, organization, address, email, and phone.
Security Significance: Uncovers contact emails and primary DNS server addresses for DNS enumeration.

> **EXAM POINT: WHAT WHOIS CANNOT RETRIEVE (NPTEL ASSIGNMENT 4 QUESTION 2)**
>
> **Question:** Which of the following information CANNOT be retrieved using a Whois lookup?
> a. Domain registration details | b. Name servers | c. Contact info | d. Historical website snapshots | e. Expiration date
> **Correct Answer: d (Historical website snapshots)**
> *Explanation:* Whois provides domain registration data. Historical website snapshots require web archives like Archive.org!

2.3 Open Web Profiling: Netcraft & Archive.org

1. Netcraft: Profiles website infrastructure, hosting history, SSL details, and subdomains.
2. Archive.org (Wayback Machine): A digital library that captures historical web snapshots over time.
Use Case: Historical snapshots often reveal old subdomains or deprecated configuration files.

2.5 Google Search Operators & Advanced Queries

Advanced search operators enable focused queries within search engines to find specific public file types and site structures.

Operator	Syntax Example	Functional Purpose & Output
site:	site:example.com	Restricts search results strictly to the specified domain.
site: with negation	site:example.com -site:www.example.com	Excludes the main www host to discover subdomains.
intitle:	intitle:"index of/"	Searches for specific terms in HTML titles.
inurl:	inurl:login	Searches for matching text inside the URL structure.
filetype:	filetype:pdf or filetype:xls	Restricts results to specific file formats.
Combination Query	site:example.com filetype:ppt "security testing"	Combines domain, file type, and string matches.

2.6 Automated OSINT Harvesting: TheHarvester

theharvester is a command-line tool in Kali Linux that automates collecting emails, subdomains, and IP addresses from public search engines and PGP servers.

Syntax & Execution Commands:
• Display Help Menu: theharvester -h
• Perform Full Domain Scan: theharvester -d example.com -b all
- -d: Specifies target domain.
- -b: Specifies data source engine (e.g., google, bing, or all).
Output: Generates lists of emails and hostnames/IPs for analysis.

Module 2 Quick Revision Q&A;:

Q1: Why is passive information gathering preferred as the first step in reconnaissance?
Answer: Because it collects intelligence without sending packets directly to the target system, resulting in zero log entries on target firewalls.
Q2: What is the output of the search query site:example.com filetype:xls "report"?
Answer: It searches Google's index for Excel files on example.com that contain the exact term 'report'.

MODULE 3: LECTURE 18 — ACTIVE RECONNAISSANCE & NMAP SCANNING TECHNIQUES

3.1 DNS Enumeration & Zone Transfer Vulnerability

Simple Explanation: Once passive intelligence is gathered, an ethical hacker transitions to **Active Reconnaissance**—sending probes directly to target systems to map live servers, open ports, and operating systems. Active reconnaissance begins with **DNS Enumeration** using tools like host or dig.

Core DNS Query Commands:
• **Name Server Enumeration:** host -t ns example.com (Retrieves authoritative DNS servers for target).
• **Mail Exchange Enumeration:** host -t mx example.com (Retrieves primary mail gateways handling corporate mail).
• **DNS Zone Transfer Request:** host -l example.com ns1.example.com

How Zone Transfer Works: A DNS Zone Transfer (AXFR) is a mechanism where a secondary DNS server requests a complete copy of the domain's zone file from the primary name server. If misconfigured to allow public requests, an auditor receives a complete map of all internal and external IP addresses, subdomains, and hostnames!

SECURITY IMPACT: MISCONFIGURED DNS ZONE TRANSFERS

Vulnerability Impact: Allows unauthenticated users to dump the entire internal DNS zone map.
Prevention / Defense: Restrict AXFR requests on primary DNS servers to explicitly authorized secondary DNS IP addresses only, blocking all public transfer queries.

3.2 Host Discovery Sweeps with Nmap

Before scanning 65,535 ports on a system, Nmap performs **Host Discovery** (Ping Sweep) to identify which IP addresses are online.

Host Discovery Method	Nmap Flag	Packet Types Sent & Alive Confirmation Signal
ICMP Echo Sweep	-PE (or -sP / -sn)	Sends ICMP Type 8 (Echo Request). Host is alive if it replies with ICMP Type 0 (Echo Reply)!
TCP SYN Ping	-PS	Sends TCP SYN to port 80/443. Alive host replies with SYN-ACK or RST.
TCP ACK Ping	-PA	Sends TCP ACK to port 80. Alive host replies with RST.
UDP Ping Sweep	-PU	Sends empty UDP packet to port 40125. Alive host returns ICMP Port Unreachable.
ICMP Netmask Ping	-PM	Sends ICMP Type 17 (Address Mask Request). Alive host returns Type 18 reply.

NPTEL ASSIGNMENT 4 QUESTIONS 3 & 4 HIGHLIGHT

Q3: How does host discovery using an ICMP Echo sweep work?
Answer: An ICMP Type-8 request (Echo Request) is sent, and an ICMP Type-0 reply (Echo Reply) confirms the host is alive.
Q4: Which Nmap options perform TCP-based host discovery sweeps?
Answer: -PS (TCP SYN ping) and -PA (TCP ACK ping).

3.3 Nmap Port Scanning Mechanics & Response Analysis

Nmap offers multiple scanning modes to probe TCP and UDP ports. Understanding exact packet handshakes and target responses is critical for NPTEL exams.

Scan Type	Flag	How it Works Step-by-Step	Response for OPEN Port	Response for CLOSED Port
Stealth SYN Scan	-sS	Nmap sends TCP SYN packet. Does NOT complete 3-way handshake (sends RST after SYN-ACK).	SYN-ACK received	RST received
TCP Connect Scan	-sT	Completes full TCP 3-way handshake via host OS socket API (SYN -> SYN-ACK -> ACK).	Full Connection Established	RST received
UDP Scan	-sU	Sends raw UDP packets to target ports. UDP is connectionless.	No Response (or UDP data reply)	ICMP Port Unreachable (Type 3, Code 3)

Scan Type	Flag	How it Works Step-by-Step	Response for OPEN Port	Response for CLOSED Port
ACK Scan	-sA	Sends TCP ACK packets. Used to map firewall rules (Unfiltered vs Filtered).	RST received (Unfiltered)	No Response or ICMP Error (Filtered)

EXAM POINT: TCP SYN SCAN & REASON FLAG (NPTEL ASSIGNMENT 4 QUESTIONS 6 & 10)

Q6: In a TCP SYN (stealth) scan, which responses indicate open or closed ports?

• SYN-ACK received = Port is OPEN.

• RST received = Port is CLOSED.

Q10: If --reason shows 'syn-ack' for an open port in a SYN scan, what does it mean?

Answer: The port is open because Nmap received a SYN-ACK response from the target.

3.4 Nmap Port States Defined

• **Open:** An application is actively listening for incoming TCP/UDP connections on the port.

• **Closed:** The port is accessible (no firewall blocking), but no application is listening. Host returns RST or ICMP Unreachable.

• **Filtered:** A firewall, filter, or router is blocking probes. Nmap cannot determine if port is open or closed.

• **Unfiltered:** The port is accessible (Nmap received RST from ACK scan), but open/closed state is unknown.

• **Open|Filtered / Closed|Filtered:** Nmap cannot distinguish between the two states due to lack of packet response.

3.5 OS Detection, Service Versioning & Firewall Bypassing

Core Advanced Scanning Flags:

• **OS Detection (-O):** Probes TCP/IP stack fingerprint differences (window size, TCP options, TTL).

• **Service Version Detection (-sV):** Interrogates open ports to determine exact application versions.

• **Aggressive Scan (-A):** Combines OS detection (-O), version detection (-sV), script scanning (-sC), and traceroute.

• **Bypass Ping Block (-Pn):** Treats target as online, skipping host discovery (essential when firewalls block ICMP pings).

• **Packet Fragmentation (-f):** Fragments probe packets into tiny 8-byte chunks to evade simple packet filter firewalls.

3.7 Nmap Timing Templates (-T0 to -T5) & Output Options

Timing Templates: -T0 (Paranoid - IDS evasion), -T1 (Sneaky), -T2 (Polite), -T3 (Normal - Default), -T4 (Aggressive - Fast reliable networks), -T5 (Insane).

Output Formats:

• -oN: Normal human-readable text file.

• -oX: XML format for automated reporting.

• -oG: Grepable format for fast command-line parsing (using grep, awk).

• -oS: Script Kiddies format.

Module 3 Quick Revision Q&A;:

Q1: Why does a TCP SYN scan not complete the three-way handshake?

Answer: After receiving SYN-ACK from an open port, Nmap sends an RST packet to abort the connection, avoiding full connection logging in application event logs.

Q2: What command executes an aggressive scan with version detection on IP 192.168.0.106?

Answer: nmap -A -T4 192.168.0.106

MODULE 4: LECTURE 19 — INSTALLING & CONFIGURING NESSUS VULNERABILITY SCANNER

4.1 Overview of Nessus Vulnerability Scanner

Simple Explanation: While Nmap identifies open ports on a target host, **Nessus** acts as a comprehensive security auditing engine that checks target services against a database of known software flaws. Nessus is a proprietary vulnerability scanner developed by Tenable, widely used by security professionals to audit networks for missing software updates and misconfigurations.

Why it is Needed: Modern corporate networks host thousands of applications and operating systems. Manually verifying every flaw on every host is impossible. Nessus automates this process by running specialized vulnerability check components called **Plugins**.

4.2 Command-Line Installation & Service Management

Step-by-Step Installation Protocol on Kali Linux:

1. **Package Installation:** Execute package installer with elevated privileges:

sudo apt install nessus

• sudo: Executes installer with administrative privileges.
• apt: Package management utility on Debian systems.

2. **Start Background Service Daemon:**

/etc/init.d/nessusd start

• Starts the background nessusd service that powers scan execution engines.

4.4 Accessing the Nessus Web Management Interface

Web Management URL: https://kali:8834

• **HTTPS Protocol:** Encrypts web traffic between browser and scanner.
• **Port 8834:** The default TCP port assigned to the Nessus web console.
• **SSL Certificate Exception:** On first access, web browsers display a security warning because Nessus uses a self-signed certificate. Users must click Advanced → Proceed to access the web interface.

> **EXAM POINT: NESSUS WEB INTERFACE PORT & DEPLOYMENT SPECS**
>
> • **Default Web Port:** TCP Port **8834**.
> • **Daemon Service Command:** /etc/init.d/nessusd start
> • **Core Component: Plugins** (modular vulnerability check scripts compiled during setup).
> • **Activation Key:** Code provided by Tenable to download and compile plugin feeds.

4.5 User Registration, Activation & Plugin Compilation

Activation & Feed Update Pipeline:

1. **Registration:** User provides registration details to obtain an Activation Code.
2. **Code Validation:** Input code links Nessus to update servers.
3. **Plugin Downloading:** Nessus downloads vulnerability definition files.
4. **Plugin Compilation:** Nessus processes and compiles plugin code into an optimized format for fast scanning.

Module 4 Quick Revision Q&A;:

Q1: On which default port does the Nessus web interface run?
Answer: TCP Port 8834.
Q2: What are Nessus Plugins?
Answer: Plugins are modular components containing specific vulnerability check logic that allow Nessus to detect security weaknesses.

MODULE 5: LECTURE 20 — VULNERABILITY ASSESSMENT WITH NESSUS & PENETRATION TESTING OVERVIEW

5.1 Initiating a Scan & Setting Parameters

Simple Explanation: Once Nessus is installed and activated, you log into the web console to launch a scan. You select **New Scan** and choose a template based on your audit scope. For maximum flexibility, the **Advance Scan** template is selected.

Target Specification Syntax:
• **Single IP:** 192.168.0.104
• **Multiple Target IPs:** Comma-separated list (e.g., 192.168.0.104, 192.168.0.106).
• **Subnet Range:** CIDR notation (e.g., 192.168.0.0/24).

5.2 Configuring Discovery, Assessment & Tuning Options

Scan Configuration Section	Key Parameters Configured	Operational Purpose & Impact
Discovery Options	Ping method, ARP, TCP, ICMP (Max tries = 2)	Identifies live hosts on the target network.
Port Scanning & Encodings	Local enumeration via SSH, WMI, SNMP; SSL/TLS cipher audit	Discovers open ports and verifies cipher strength.
Assessment Types	Brute force, Web application, Windows, Malware checks	Enables or disables specific check categories.
Performance Tuning	Timeout = 5s, Max checks/host = 5, Max hosts/scan = 5	Prevents scan traffic from flooding network links.

5.3 Analyzing Severity Ratings & Lecture Findings

Nessus categorizes all findings into 5 severity levels: **Critical** (Red), **High** (Orange), **Medium** (Yellow), **Low** (Green), and **Informational** (Blue).

Target IP	Severity Breakdown	Key Discovered Flaws & Vulnerabilities	Security Risk & CVE References
192.168.0.104	70 Total (9 Critical, 5 High, 23 Medium, 8 Low, 129 Info)	Bind Shell Backdoor Detection	An unauthenticated shell is listening on a remote port, allowing direct remote command execution!

Target IP	Severity Breakdown	Key Discovered Flaws & Vulnerabilities	Security Risk & CVE References
192.168.0.106	39 Total (1 Critical, 2 Medium, 36 Info)	MS17-010 SMB Server Update & MS17-047	Critical SMB flaw (associated with WannaCry / EternalBlue; CVE-2017-0143 to 0148) & SAM privilege escalation.

EXAM POINT: CRITICAL LECTURE VULNERABILITIES TO MEMORIZE

- **Bind Shell Backdoor:** A severe flaw where a shell listens on a remote port without requiring authentication, granting direct command shell access to anyone who connects.
- **MS17-010:** Critical Microsoft Windows SMB Server security update addressing vulnerabilities exploited by WannaCry ransomware (CVE-2017-0143 through CVE-2017-0148).
- **MS17-047:** Privilege elevation flaw in Windows Security Account Manager (SAM) and Local Security Authority.

5.4 Vulnerability Assessment vs. Penetration Testing

A fundamental distinction in cybersecurity that appears frequently on NPTEL exams is the difference between **Vulnerability Assessment** and **Penetration Testing**.

Dimension	Vulnerability Assessment	Penetration Testing
Primary Goal	Identify and catalog ALL possible potential security flaws	Actively verify exploitability of specific flaws
Execution Approach	Automated scanning (e.g., using Nessus, OpenVAS)	Manual and automated exploitation (e.g., using Metasploit)
Phase in Lifecycle	Discovery Phase (Provides security roadmap)	Exploitation Phase (Confirms actual breach impact)
Target Impact	Passive/Non-disruptive identification of flaws	Active probing that can disrupt services if not scoped carefully
Deliverable Output	Comprehensive list of flaws with severity ratings	Proof-of-concept breach report confirming exploit success

NPTEL LECTURE & EXAM DEFINITION: ASSESSMENT VS PEN TEST

Vulnerability Assessment: Discovers all potential entry points and security weaknesses across target machines.
Penetration Testing: Takes those identified weaknesses and attempts actual exploitation to verify which ones work!

Module 5 Quick Revision Q&A;:

Q1: What is a Bind Shell Backdoor?
Answer: A backdoor where a command shell listens on a target port without authentication, allowing remote users to connect and execute system commands.
Q2: What is the main difference between Vulnerability Assessment and Penetration Testing?
Answer: Vulnerability Assessment identifies potential weaknesses (a list of flaws), whereas Penetration Testing actively attempts to exploit those flaws to prove exploitability.

MODULE 6: WEEK 4 REVISION & NPTEL EXAM PREPARATION PAGES

6.1 Quick Week 4 Core Revision Summary

Core Takeaways to Memorize:

• **Virtualization:** Allows running multiple isolated guest VMs on one physical host using VirtualBox.
• **Kali Linux:** Attacker machine configured with 2 GB RAM, 20 GB VDI disk, GRUB on /dev/hda.
• **VirtualBox NAT Mode:** Default mode. Assigns private IP, permits outbound internet, hides guest VM from external networks.
• **Passive Reconnaissance:** Gathers intelligence without touching target servers (WHOIS, Netcraft, Archive.org, Google Dorks, TheHarvester).
• **WHOIS:** Provides registration dates, contact info, and name servers (CANNOT retrieve historical website snapshots).
• **Active Reconnaissance & Nmap:** Probes live targets directly (Host discovery, port scans, OS detection, versioning).
• **Nmap SYN Scan (-sS):** Stealth scan. Returns SYN-ACK for open ports, RST for closed ports.
• **Nmap Firewall Bypassing:** Use -Pn to skip ping, -f to fragment probe packets into 8-byte chunks.
• **Nessus Scanner:** Runs on TCP Port 8834, managed via /etc/init.d/nessusd start, powered by **Plugins**.
• **Assessment vs Pen Testing:** Assessment discovers flaws; Pen Testing actively attempts exploitation.

6.2 Master Glossary of Key Terms

Term	Technical Definition	Exam & Security Significance
Hypervisor	Software monitor allowing host to run guest VMs.	Enables isolated lab environments.
WHOIS	Public protocol querying domain registry databases.	Returns domain registration and owner contact data.
Google Dorking	Using advanced search operators in search engines.	Uncovers exposed files and misconfigured portals.
TheHarvester	Python tool gathering emails, hostnames, and subdomains.	Automates OSINT data collection.
SYN Scan (-sS)	TCP stealth scan that aborts before finishing handshake.	Returns SYN-ACK for open ports without full connection.
Nessus Plugins	Modular scripts containing specific vulnerability checks.	Core intelligence element of Nessus.
MS17-010	Microsoft Windows SMB server security update.	Patches EternalBlue flaw exploited by WannaCry.
Bind Shell	Backdoor shell listening on port without authentication.	Critical finding allowing direct remote shell access.

6.3 Key Concept Master Comparisons

Comparison Category	Concept A	Concept B	Key Distinguishing Factor
Reconnaissance Type	Passive Reconnaissance	Active Reconnaissance	Passive sends no packets to target; Active probes target directly.
Nmap Scan Modes	SYN Stealth Scan (-sS)	TCP Connect Scan (-sT)	SYN scan aborts with RST; Connect scan completes 3-way handshake.
VirtualBox Network	NAT Mode (Default)	Bridged Adapter Mode	NAT hides VM behind host IP; Bridged gives VM real LAN IP.
Audit Category	Vulnerability Assessment	Penetration Testing	Assessment catalogs potential flaws; Pen Test actively exploits them.

6.4 Nmap & Nessus Command Syntax Quick Reference Sheet

1. **Nmap Host Discovery:** nmap -sn 192.168.0.0/24 (Ping sweep subnet)
2. **Nmap SYN Stealth Scan:** nmap -sS -T4 -p 1-1000 192.168.0.106
3. **Nmap Service & OS Audit:** nmap -sV -O -T4 192.168.0.106
4. **Nmap Aggressive Scan:** nmap -A -T4 192.168.0.106
5. **Nmap Firewall Evasion:** nmap -Pn -f 192.168.0.106 (Skip ping + fragment packets)
6. **TheHarvester OSINT Query:** theharvester -d example.com -b all
7. **Nessus Installation & Daemon Start:** sudo apt install nessus && /etc/init.d/nessusd start

6.5 Important Solved Analysis Examples

SOLVED EXAMPLE 1: Nmap Probe Reason Analysis

Problem: You run nmap -sS --reason 192.168.0.106. Port 80 displays status open with reason syn-ack. What does this indicate?

Step-by-Step Solution:

1. Nmap sent a TCP SYN packet to port 80 of host 192.168.0.106.
2. The target host responded with a TCP SYN-ACK packet.
3. Receiving SYN-ACK confirms that an application is actively listening on port 80.
4. Nmap then sent an RST packet to close the connection without completing the 3-way handshake.

Conclusion: Port 80 is confirmed OPEN because a SYN-ACK packet was received.

6.6 NPTEL Exam Practice MCQs (With Solutions)

PRACTICE QUESTION

Q1: What is the primary purpose of a Hypervisor in a penetration testing lab setup?

a. It encrypts all network traffic between virtual machines.

b. It allows creation and management of multiple virtual machines on a single physical system.

c. It is a hack-proof security layer for the host OS.

d. It automatically patches vulnerabilities on guest machines.

Correct Answer: b | *Explanation:* A hypervisor allows one physical host to run multiple VMs sharing host CPU and RAM.

PRACTICE QUESTION

Q2: Which of the following information CANNOT typically be retrieved using a Whois lookup?
a. Domain registration details | b. Name servers | c. Registrant contact information | d. Historical snapshots of the website | e. Domain expiration date
Correct Answer: d | *Explanation:* Historical website snapshots require archive services like Archive.org's Wayback Machine, not Whois.

PRACTICE QUESTION

Q3: How does host discovery using an ICMP Echo sweep work?
a. An ICMP type-8 request is sent, and an ICMP type-0 reply confirms the host is alive.
b. A TCP SYN packet is sent, and an ACK confirms the host is alive.
c. It broadcasts ARP requests to identify all hosts on the segment.
Correct Answer: a | *Explanation:* ICMP Echo Request is type 8; ICMP Echo Reply is type 0.

PRACTICE QUESTION

Q4: Which NMAP option(s) can be used to perform a TCP-based host discovery sweep?
a. -PE | b. -PS | c. -PA | d. -PU | e. -PM
Correct Answer: b, c | *Explanation:* -PS (TCP SYN ping) and -PA (TCP ACK ping) perform TCP host discovery.

PRACTICE QUESTION

Q5: During the TCP three-way handshake, what type of message does the client send first?
a. ACK | b. SYN | c. SYN-ACK | d. RST | e. FIN
Correct Answer: b | *Explanation:* The client initiates connection by sending a SYN packet with initial sequence number.

PRACTICE QUESTION

Q6: In a TCP SYN (stealth) scan, which packet response(s) indicate that a port is open or closed, respectively?
a. SYN-ACK received indicates the port is open.
b. RST received indicates the port is closed.
c. ACK received indicates the port is open.
Correct Answer: a, b | *Explanation:* In SYN scan, SYN-ACK indicates open; RST indicates closed.

PRACTICE QUESTION

Q7: Which of the following statement(s) is/are true regarding the default NAT mode in VirtualBox?
a. Assigns unique public IP address to each VM.
b. Assigns the same private/virtual IP address structure to guest OSs.
c. Virtual machines using this mode can access the internet.
d. Virtual machines are directly reachable from outside by default.
Correct Answer: b, c | *Explanation:* NAT mode assigns private virtual IPs and permits outbound internet access, hiding guests behind the host.

PRACTICE QUESTION

Q8: Which NMAP option(s) can be used for OS and/or service version detection?
a. -sn | b. -O | c. -sV | d. -Pn | e. -A
Correct Answer: b, c, e | *Explanation:* -O detects OS, -sV detects version, and -A performs aggressive scan combining both.

PRACTICE QUESTION

Q9: If ports 80 and 443 are found open on a target system, what can be reasonably inferred?
a. Target is running SSH. | b. Target is hosting a website (HTTP/HTTPS). | c. Target is running a mail server.
Correct Answer: b | *Explanation:* Ports 80 and 443 are standard HTTP and HTTPS web server ports.

PRACTICE QUESTION

Q10: If --reason shows 'syn-ack' for an open port in a SYN scan, what does it mean?
a. Port is open because NMAP received a SYN-ACK response.
b. Port is closed.
c. Target sent an RST packet.
Correct Answer: a | *Explanation:* Receiving SYN-ACK proves the port is open and listening.

PRACTICE QUESTION

Q11: Which default TCP port does the Nessus web interface use for management access?
a. 80 | b. 443 | c. 8080 | d. 8834
Correct Answer: d | *Explanation:* Nessus web interface listens on TCP port 8834.

PRACTICE QUESTION

Q12: Which command initiates the background Nessus service on Kali Linux?
a. service nessus run | b. /etc/init.d/nessusd start | c. nessus --start
Correct Answer: b | *Explanation:* The Nessus daemon is started via /etc/init.d/nessusd start.

PRACTICE QUESTION

Q13: What Nmap flag is used to skip ICMP host discovery when firewalls block pings?
a. -sS | b. -Pn | c. -f | d. -sU
Correct Answer: b | *Explanation:* -Pn instructs Nmap to treat all targets as online and skip host discovery.

PRACTICE QUESTION

Q14: What is the primary function of Nessus Plugins?
a. To encrypt scan reports. | b. To run specific vulnerability checks and detection scripts. | c. To manage VM disk space.
Correct Answer: b | *Explanation:* Plugins contain the specific vulnerability detection logic and scripts.

PRACTICE QUESTION

Q15: What is a Bind Shell Backdoor?
a. A shell listening on a remote port without authentication.
b. A firewall rule blocking SSH.
c. An encrypted VPN tunnel.
Correct Answer: a | *Explanation:* A bind shell listens on a port without authentication, allowing direct command execution.

6.7 Oral Viva Questions & Easy Answers

#	Oral Viva Question	Concise Answer for Oral Exam
1	**1. What is Virtualization?**	Creating software-based virtual hardware to run multiple OSs on one physical computer.
2	**2. Why is Kali Linux preferred for ethical hacking?**	It is pre-loaded with over 600 penetration testing and security auditing tools.
3	**3. What is the role of the GRUB bootloader?**	It loads the Linux kernel into memory during virtual machine bootup.
4	**4. What does WHOIS stand for and do?**	A protocol to query public databases for domain registration details and ownership.
5	**5. What is Google Dorking?**	Using advanced search operators to find specific indexed files and misconfigurations.
6	**6. What command displays theHarvester help menu?**	theharvester -h
7	**7. What is the difference between active and passive reconnaissance?**	Passive sends no packets to target; active directly probes target systems.
8	**8. Why is SYN scan called a stealth scan?**	Because it aborts the connection with an RST before completing the 3-way handshake.
9	**9. What does Nmap flag -Pn do?**	Skips ping host discovery and assumes the target is online.
10	**10. What does Nmap flag -f do?**	Fragments probe packets into 8-byte chunks to bypass simple packet filters.
11	**11. On which port does Nessus listen by default?**	TCP Port 8834.
12	**12. What are Nessus Plugins?**	Modular scripts containing specific vulnerability detection logic.
13	**13. What is MS17-010?**	A critical Microsoft Windows SMB update fixing vulnerabilities exploited by WannaCry.
14	**14. What is a Bind Shell?**	A backdoor shell listening on a target port without authentication.
15	**15. What is the difference between Vulnerability Assessment and Pen Testing?**	Assessment discovers potential flaws; Pen Testing actively attempts exploitation.

6.8 Final Revision Checklist

Mark checkboxes as you master each topic before the NPTEL exam:

[ ] Understand Virtualization, Hypervisors, and VirtualBox installation.
[ ] Memorize Kali Linux setup specs (2 GB RAM, 20 GB VDI, GRUB on /dev/hda).
[ ] Differentiate VirtualBox NAT, Bridged, Host-Only, and Internal networking modes.
[ ] Differentiate Passive Reconnaissance vs. Active Reconnaissance.
[ ] Master WHOIS domain queries and understand what Whois CANNOT retrieve.
[ ] Master Google Dorking operators (site:, intitle:, inurl:, filetype:).
[ ] Memorize theharvester command flags (-d, -b all).
[ ] Master DNS enumeration commands and understand Zone Transfer risks.
[ ] Differentiate Nmap ping sweeps (ICMP Type 8/0, -PS, -PA, -PU, -PM).
[ ] Master Nmap scan types: Stealth SYN (-sS), Connect (-sT), UDP (-sU), ACK (-sA).
[ ] Understand Nmap port states (Open, Closed, Filtered, Unfiltered).
[ ] Understand Nmap firewall evasion flags (-Pn, -f).
[ ] Memorize Nessus port (8834), startup command (/etc/init.d/nessusd start), and Plugin compilation.
[ ] Differentiate Vulnerability Assessment (discovery) vs. Penetration Testing (exploitation).